

Incident Management & Response Policy (Evidence)

Community Health Media · CHT Platform · Source: docs/compliance/incident-response.md

CHT maintains a documented incident response runbook covering detection, escalation, containment, eradication, recovery, and post-incident review for security and availability incidents. Related DR procedures: docs/compliance/disaster-recovery.md.

Runbook excerpt

```
# Incident Response Plan
```

Operational runbook for security and availability incidents affecting the CHT Platform.

Scope: Platform (production) and staging in AWS account `233636046512`, region `us-east-1`.

Last reviewed: `_Set date when approved_`

Roles

Role	Responsibility	Contact
Incident commander	Owns timeline, decisions, comms	<code>_Name / email / phone_</code>
Engineering lead	Triage, containment, recovery	<code>_Name / email_</code>
AWS admin	IAM, Secrets Manager, RDS, ECS	<code>_Name / email_</code>
GitHub admin	Org/repo access, Actions, secrets	<code>_Name / email_</code>
Executive / legal	Customer/regulator notification	<code>_Name / email_</code>

Document substitutes when primary contacts are unavailable.

Severity levels

Level	Examples	Response target	Notification
SEV-1	Confirmed data breach, prod down, credential leak in git	Immediate (24/7)	Incident commander + executive
SEV-2	GuardDuty high/critical finding, sustained 5xx, payment DLQ growing	< 1 hour	Engineering lead + incident
SEV-3	Single alarm, non-prod issue, failed deploy	< 4 hours (business hours)	Engineering lead
SEV-4	Low-severity finding, planned maintenance follow-up	Next business day	Ticket / async

Detection sources

Amazon GuardDuty

- Scope:** One detector per account **per region**.
- us-east-1:** Managed by platform Terraform (``cht-platform-guardduty-findings`` → ``cht-platform-alerts``).
- us-east-2:** Managed by DR Terraform (``cht-platform-dr-use2-guardduty-findings`` → regional alerts topic).
- Action:** Open [GuardDuty console](https://console.aws.amazon.com/guardduty/) → switch region → Findings.

Amazon CloudWatch alarms

All alarms publish to SNS ``cht-platform-alerts`` (staging: ``cht-platform-staging-alerts``). Subscribers are configured via ```

Alarm (platform prefix)	Meaning
<code>`cht-platform-ecs-cpu-high`</code>	ECS cluster CPU > 80% (2 periods)
<code>`cht-platform-rds-cpu-high`</code>	RDS CPU > 80%
<code>`cht-platform-alb-5xx-errors`</code>	ALB target 5xx count > 10 in 5 min
<code>`cht-platform-application-errors`</code>	Backend log ERROR count > 50 in 5 min
<code>`cht-platform-email-dlq-messages`</code>	Messages in email dead-letter queue
<code>`cht-platform-payment-dlq-messages`</code>	Messages in payment DLQ: priority
<code>`cht-platform-cme-dlq-messages`</code>	Messages in CME certificate DLQ
<code>`cht-platform-scheduled-jobs-dlq-messages`</code>	Scheduled job failures

Dashboard: CloudWatch → Dashboards → ``cht-platform-dashboard`` (ECS, ALB, RDS, SQS).

Other logs and audit trails

Source	Location	Retention
CloudTrail	S3 `cht-platform-cloudtrail-*` + CloudWatch	365 days (platform)
VPC flow logs	CloudWatch	365 days
ECS application logs	`/ecs/cht-platform`	365 days
RDS PostgreSQL logs	CloudWatch (`postgresql`, `upgrade`)	Per RDS export
Admin API mutations		